

ОСОБЕННОСТИ РАЗМЕЩЕНИЯ БАЗ ПЕРСОНАЛЬНЫХ ДАННЫХ ИНФОРМАЦИОННЫХ СИСТЕМ НАУЧНО-ОБРАЗОВАТЕЛЬНЫХ УЧРЕЖДЕНИЙ

П.Ю. Пушкин

В статье проведен анализ нормативных актов по организации обработки и защите персональных данных на предмет размещения баз данных, используемых в информационных системах российских учреждений научно-образовательной сферы. С 2015 года законодательством Российской Федерации определена необходимость размещения баз персональных данных на территории нашей страны. Однако есть случаи, когда хранение персональных данных возможно и за пределами нашей страны. В работе рассмотрены такие исключения, применимые к сфере деятельности научно-образовательных учреждений. На основе автоматизированного анализа реестра операторов персональных данных определено соотношение высших учебных заведений, представивших сведения о месте нахождения своих баз данных в соответствии с Российским законодательством. Более 24% высших учебных заведений такие сведения не предоставили, что может говорить о необходимости оказания университетскому операторскому сообществу методической помощи по вопросам порядка обработки и защиты персональных данных. В ходе проведения контроля за порядком обработки персональных данных по требованию Роскомнадзора необходимо представить, в том числе, документы, подтверждающие расположение баз персональных данных информационных систем в пределах границ Российской Федерации. В работе разработаны рекомендации по размещению и документальному оформлению местонахождения баз данных, использующихся в информационных системах научно-образовательных учреждений, при использовании собственной и предоставляемой третьими лицами ИТ-инфраструктуры.

Ключевые слова: защита персональных данных, защита баз данных, персональные данные, реестр операторов персональных данных.

Введение

В соответствии со вступившими с 1 сентября 2015 года в силу изменениями в Федеральный закон «О персональных данных», на операторов дополнительно возложена обязанность обеспечить обработку персональных данных, а именно запись, накопление, хранение, систематизацию, уточнение, извлечение с использованием баз данных, расположенных на территории нашего государства [1]. Сведения о нахождении таких баз данных должны быть направлены операторами в Роскомнадзор, осуществляющий функции государственного надзора и контроля по защите прав граждан России при обработке их персональных данных [1]. Стоит отметить, что под базой данных понимается любая документированная информация, в том числе в электронном виде, содержащая персональные данные. Поэтому независимо от формы обработки персональных данных, которая может осуществляться с

применением информационных технологий и средств или без их использования, в уведомлении об обработке персональных данных должно содержаться определенное оператором место нахождения базы данных.

При организации Роскомнадзором периодических или внеплановых проверок за соблюдением требований законодательства по обработке персональных данных осуществляется, в том числе, контроль местонахождения баз персональных данных оператора, в том числе документов (письменных пояснений), описывающих их расположение.

Поэтому разработка рекомендаций по размещению баз персональных данных в соответствии с установленными законодательством требованиями является актуальной проблемой.

Целью данной статьи является повышение уровня защищенности, обрабатываемых в учреждениях научно-образовательной сферы персональных

данных, за счет разработки рекомендаций по организации размещения баз данных информационных систем и документирования их местонахождения.

Работа направлена на формирование отдельных положений отраслевых рекомендаций научно-образовательному операторскому сообществу по организации обработки и защите персональных данных.

Сведения о размещении баз персональных данных

С целью определения уровня актуальности работы проведен анализ записей, представленных в поле «Дата и основание внесения записи в реестр» Реестра операторов персональных данных (далее – Реестр) [2]. С 1 сентября 2015 года, с учетом времени формирования информационного сообщения о внесении изменений в уведомление об обработке персональных данных (далее - уведомление) операторами и включения этих сведений в Реестр, в указанном выше поле должна быть запись о нахождении баз данных, используемых научно-образовательными учреждениями в своей деятельности, на территории России.

В качестве типовых операторов для исследования Реестра выбраны высшие

учебные заведения, составляющие репрезентативную выборку из научно-образовательных учреждений России. Полученные результаты и рекомендации будут распространяться и на иные научные и образовательные учреждения. Для проверки направленных университетами сведений о нахождении баз данных, использовалась информационно-аналитическая система мониторинга выполнения операторами персональных данных требований законодательства [3]. Выборка операторов – высших учебных заведений формировалась на основе анализа открытых данных. Всего в Реестре размещены сведения о 570 из 719 высших учебных заведений [4]. На рис. 1 представлена информация о размещении университетами сведений о нахождении баз данных в Реестре, из которого следует, что сведения о местонахождении баз данных с учетом университетов, не подавших предусмотренное законодательством уведомление, не разместили 24% высших учебных заведений России. У операторов, не представивших сведения о местонахождении баз данных, в Реестре отсутствуют записи о внесении изменений в уведомления после 2015 года, за исключением двух операторов.



Рис. 1. Размещение университетами сведений о местонахождении баз персональных данных

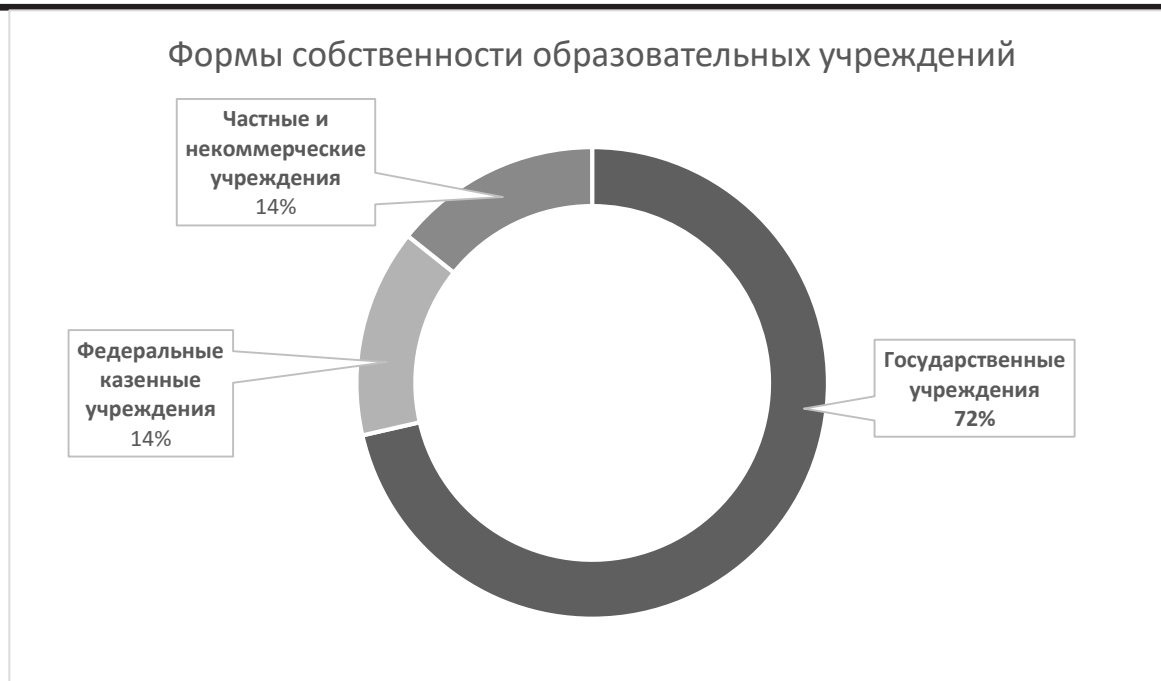


Рис. 2. Формы собственности высших учебных заведений, не представивших сведения о местонахождении баз персональных данных

На рис. 2 представлены формы собственности образовательных учреждений, реализующих программы высшего образования. Проблемы, связанные с определением местоположения баз данных, наблюдаются в учреждениях любых организационных форм, но более выражены для государственных организаций.

Полученные в результате автоматизированного анализа сведения (рис. 1, 2) указывают на необходимость и актуальность подготовки рекомендаций по организации обработки и защите персональных данных для научно-образовательных учреждений, в том числе по размещению баз данных. Контроль за местом нахождения баз данных информационных систем позволит повысить уровень безопасности персональных данных в научно-образовательных учреждениях.

Необходимость оказания методической помощи университетскому операторскому сообществу также коррелируется с результатами государственного контроля за деятельностью операторов персональных данных, проведенного Роскомнадзором в 2019 году, согласно которому большинство систематических нарушений может быть устранено организационными мерами без дополнительного финансирования [5]. По

данным, полученным в результате государственного контроля [5], сведения о местонахождении баз данных не внесены 13% всех операторов, подавших уведомления. Таким образом раздел методических рекомендаций по размещению и документированию мест нахождения баз персональных данных может использоваться и другими операторскими сообществами.

Требования к размещению баз персональных данных

Федеральным законом [1] определена обязанность операторов обеспечить запись, накопление, хранение, систематизацию, уточнение, извлечение персональных данных при их сборе с использованием находящихся на территории нашего государства баз данных. При этом на ряд действий с персональными данными, таких как использование, обезличивание, передача, блокирование эти требования не распространяются. Также, исходя из положений Федерального закона [1], к исключениям, когда базы данных могут быть размещены за пределами Российской Федерации, можно отнести следующие случаи, характерные для учреждений научно-образовательной сферы:

- при осуществлении обработки персональных данных в соответствии с международным договором или законом, если такие функции возложены на учреждение законодательством Российской Федерации;

- при выполнении научных работ, иной творческой деятельности с использованием персональных данных при условии соблюдения прав и интересов граждан.

Так, например, приведенные исключения в совокупности с требованиями п. 9 части 1 статьи 6 Федерального закона «О персональных данных», позволяют проводить научную деятельность, используя базы данных, расположенные за пределами границ Российской Федерации, при условии обезличивания персональных данных или наличия согласия субъекта на такую обработку и соблюдения требований к трансграничной передаче персональных данных, установленных действующим законодательством в указанной сфере [1].

Из положений Федерального закона [1] также следует, что собранные и актуализируемые базы данных в России, могут быть в дальнейшем переданы в иные базы данных, в том числе размещаемые на территориях иных стран. Однако, в этом случае необходимы к выполнению условия по трансграничной передаче персональных данных на территории таких государств, а

также приоритетное выполнение всех, предусмотренных Федеральным законом «О персональных данных» действий с персональными данными при их сборе, с использованием размещенных на территории нашей страны баз данных.

Стоит отдельно отметить возможность обрабатывать персональные данные граждан Европейского союза на территории Российской Федерации при выполнении требований «Общего регламента по защите данных» (GeneralDataProtectionRegulation) [6], так как научная и образовательная деятельность в настоящее время имеет трансграничный характер.

О местонахождении баз данных оператор уведомляет Роскомнадзор в установленном порядке [1]. В электронной форме уведомления, доступной для заполнения операторами на официальном ресурсе Роскомнадзора (рис. 3), указываются страна, адрес центра обработки данных, его принадлежность оператору (собственный или нет) [7]. Стоит отметить, что для каждой использующейся в учреждении базы данных, необходимо указать свои сведения, например, если в филиалах научно-образовательного учреждения используются собственные серверные мощности и обработка персональных данных осуществляется в иных целях.

Сведения о местонахождении базы данных информации, содержащей персональные данные граждан РФ

База данных №1

Страна *

Россия

Адрес ЦОДа *

выбрать

Собственный ЦОД *

добавить сведения

удалить

Добавить ИС или способ обработки

Рис. 3. Скриншотэлектронной формы об обработке персональных данных

При проведении государственного контроля за организацией обработки персональных данных и ее соответствием требованиям законодательства Роскомнадзор рассматривает локальные акты оператора, в том числе определяющие порядок обработки персональных данных.

Приказом №21 ФСТЭК России [8] определено, что для информационной системы персональных данных любого уровня защищенности требуется обеспечить контроль за физическим доступом к техническим средствам обработки информации и помещениям, в которых они размещены. При использовании в информационных системах персональных данных средств криптографической защиты информации могут предъявляться дополнительные требования к обеспечению безопасности кабинетов и технологических помещений, в которых размещены элементы таких систем, в зависимости от установленного уровня их защищенности.

Таким образом, место размещения серверного оборудования, обрабатывающего базы персональных данных, и порядок доступа к нему должны быть отражены в локальных актах оператора.

Рекомендации по размещению и документированию баз данных

Для исключения несанкционированного доступа к серверам, обрабатывающим персональные данные, рекомендуется использовать отдельные или серверные помещения, размещенные в пределах границ контролируемой зоны. Доступ в такие помещения должен обеспечиваться системой контроля и управления доступом и (или) с помощью журнала вскрытия помещения серверной. Перечень должностных лиц, допущенных в серверные помещения, утверждается руководителем учреждения. Должен быть установлен порядок доступа в серверные помещения в рабочее и нерабочее время, при возникновении нештатных ситуаций, проведении ремонтных, уборочных и иных работ.

Помещения, в которых размещается серверное оборудование информационных систем персональных данных, должны быть оборудованы надежными запирающими устройствами, системами охранной и пожарной сигнализации, кондиционирования, резервного электропитания.

Для оформления нахождения баз данных на территории Российской Федерации с использованием собственных серверных мощностей научно-образовательному учреждению рекомендуется использовать следующие документы:

- подтверждающие приобретение учреждением серверного оборудования, используемого для обработки баз данных: конкурсные, платежные и другие отчетные документы;
- подтверждающие постановку серверного оборудования на инвентарный учет учреждения: инвентарные карточки учета;
- приказ руководителя об утверждении границ контролируемой зоны учреждения с указанием на схеме помещения, в котором размещено серверное оборудование информационной системы персональных данных;
- подтверждающие законное пользование помещениями, в которых размещено серверное оборудование: договор аренды, безвозмездного пользования, свидетельство о праве собственности;
- определяющие состав информационной системы персональных данных учреждения, например, акт определения уровня защищенности информационной системы, технический паспорт автоматизированной системы;
- акты проведения оценки эффективности принимаемых мер по защите персональных данных, которую в соответствие с приказом №21 ФСТЭК России требуется проводить не реже одного раза в три года [8].

Если для хранения и обработки персональных данных в своей деятельности научно-образовательными учреждениями используются сторонние центры обработки данных, дополнительно необходимо:

- получить дополнительное согласие от субъектов персональных данных на передачу их данных третьим лицам с указанием конкретного юридического лица или индивидуального предпринимателя, перечислением всех, совершаемых с персональными данными действий, цели такой обработки;

- обеспечить защищенный по требованиям безопасности информации канал передачи данных от внешнего центра обработки данных до локальной вычислительной сети учреждения;

- с третьими лицами, оказывающими услуги хостинга, должны быть заключены соответствующий договор, а также соглашение о конфиденциальности обрабатываемых персональных данных и обеспечении их безопасности.

В заключаемом с третьими лицами соглашении о конфиденциальности необходимо указать конкретные требования по защите персональных данных с учетом необходимости обеспечения требуемого уровня защищенности информационных систем учреждения. Требование о месте нахождения серверов с базами данных учреждения на территории Российской Федерации должно быть явно прописано в договоре на оказание таких услуг.

Заключение

Проведенные в данной работе исследования позволяют сформировать следующие основные выводы.

На основе автоматизированного анализа Реестра определена необходимость разработки рекомендаций по размещению баз данных для учреждений научно-образовательной сферы - 24% высших учебных заведений, вне зависимости от их

формы собственности или организации, не направили, предусмотренные законодательством сведения о месте нахождения своих баз персональных данных.

Для научно-образовательных учреждений определены требования и условия использования баз данных, находящихся за пределами Российской Федерации.

Разработаны рекомендации по размещению и документированию места нахождения баз персональных данных при их обработке в собственных и сторонних центрах обработки данных. С учетом перечисленных условий и требований, предъявляемых к использованию сторонних центров обработки данных, научно-образовательным учреждениям целесообразно использовать собственную ИТ-инфраструктуру для обработки персональных данных. Вместе с тем ряд научных задач, связанных, например, с использованием обезличенной персональной информацией, возможно решать с использованием широко используемых облачных сервисов, инфраструктура которых может быть размещена в других странах.

При взаимодействии в научно-образовательной сфере с международными организациями и (или) сборе и дальнейшей обработке персональных данных иностранных граждан необходимо применять законодательство этих стран. Европейский регламент (GDPR) предоставляет возможность обрабатывать данные граждан Евросоюза на территории нашего государства при соблюдении надлежащего уровня их защиты.

Результаты работы могут использоваться иными операторскими сообществами для формирования методических рекомендаций по организации размещения баз данных информационных систем.

Работа выполнена в рамках государственного задания Министерства науки и высшего образования Российской Федерации.

Список литературы

1. Федеральный закон от 27.07.2006 №152-ФЗ «О персональных данных». – URL: <http://pravo.gov.ru/proxy/ips/?docbody&nd=102108261> (дата обращения 24.01.2021).
2. Реестр операторов, осуществляющих обработку персональных данных: [сайт]. URL: <https://rkn.gov.ru/personal-data/register/> (дата обращения: 24.01.2021).
3. Лось В.П., Никульчев Е.В., Пушкин П.Ю., Русаков А.М. Информационно-аналитическая система мониторинга выполнения операторами персональных данных требований законодательства // Проблемы информационной безопасности. Компьютерные системы. 2020. №3. С. 16-23.
4. Пушкин П.Ю., Русаков А.М. Результаты автоматического интеллектуального анализа отдельных полей реестра операторов персональных данных // International Journal of Open Information Technologies ISSN: 2307-8162. V. 9. No.1, 2021. С. 37-47.
5. Отчет о деятельности Уполномоченного органа по защите прав субъектов персональных данных за 2019 год. [Электронный ресурс]. – URL: https://rkn.gov.ru/docs/Otchet_UO-2019_new.pdf (дата обращения: 24.01.2021).
6. Регламент Европейского Парламента и Совета Европейского Союза 2016/679 от 27 апреля 2016 г. о защите физических лиц при обработке персональных данных и о свободном обращении таких данных, а также об отмене Директивы 95/46/ЕС. URL: <http://base.garant.ru/71936226/>. (дата обращения 24.01.2021).
7. Электронная форма уведомления об обработке персональных данных: [сайт]. URL: <https://pd.rkn.gov.ru/operators-registry/notification/form/> (дата обращения: 24.01.2021).
8. Приказ ФСТЭК России от 18.02.2013 №21 «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных». – URL: <http://docs.cntd.ru/document/499005278/> (дата обращения 13.02.2021).

Российская академия образования
The Russian Academy of Education

Московский институт радиотехники, электроники и автоматики – Российский
технологический университет
Moscow Institute of radio engineering, electronics and automation – Russian technological
university

Поступила в редакцию 12.02.2021

Информация об авторе

Пушкин Павел Юрьевич – канд. техн. наук, ведущий аналитик Дата-Центра Российской академии образования, доцент кафедры «Защита информации», МИРЭА – Российский технологический университет, e-mail: p.pushk@mail.ru

FEATURES OF POSITIONING PERSONAL DATABASES OF INFORMATION SYSTEMS OF SCIENTIFIC AND EDUCATIONAL INSTITUTIONS

P.Yu. Pushkin

The article analyzes normative acts on the organization of processing and protection of personal data for the location of databases used in information systems of Russian institutions of the scientific and educational sphere. Since 2015, Russian legislation has provided for the placement of personal data bases on the territory of our state. However, there are cases when the storage of personal data is possible outside our country. The paper considers such exceptions applicable to the field of activities of scientific and educational institutions. On the basis of an automated analysis of the register of personal data operators, the ratio of higher educational institutions that provided information about the location of their databases in accordance with the legislation of the Russian Federation was determined. More than 24% of higher educational institutions did not provide such information, which may indicate the need to provide the university operator community with methodological assistance on organizing the processing and protection of personal data. In the course of state control over the organization of personal data processing, it is required to submit, among other things, documents confirming the placement of databases of personal data of information systems on the territory of the Russian Federation. Recommendations have been developed for placing and documenting the location of databases, when processing them in the information systems of research and educational institutions using their own and provided by third parties IT infrastructure.

Keywords: personal information, personal data protection, register of personal information operators.

Submitted 12.02.2021

Information about the author

Pavel Yu. Pushkin – Cand. Sc. (Technical), leading data Center analyst, The Russian Academy of Education
Docent at the Department of Data protection, MIREA – Russian technological university, e-mail: p.pushk@mail.ru